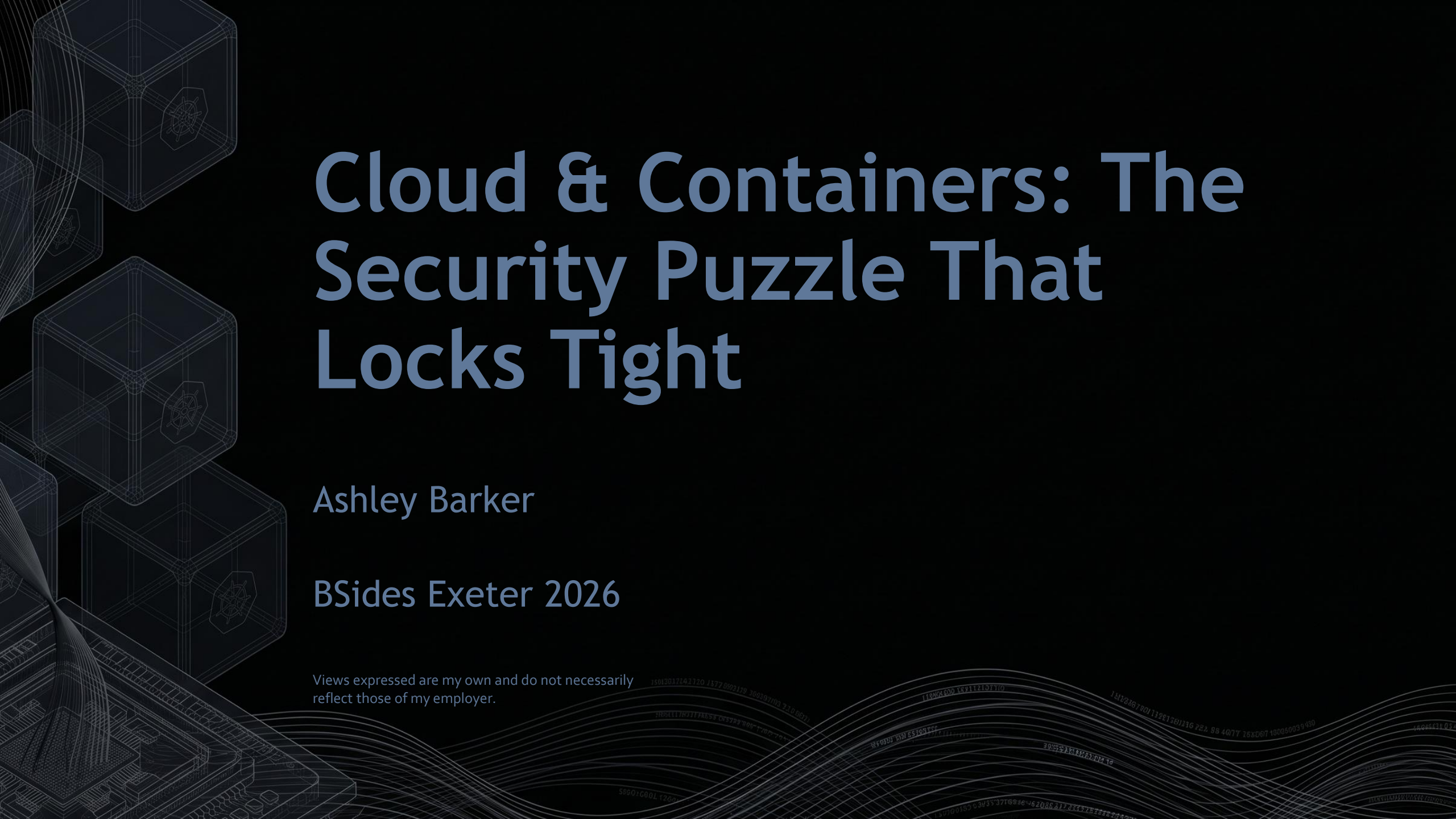


The background is a dark blue gradient. On the left side, there are several wireframe cubes of varying sizes, some of which have a small circular logo on their faces. At the bottom left, there is a detailed wireframe illustration of a computer circuit board. The bottom right corner features a series of white, wavy lines that resemble a stylized representation of data or a signal. The main title is centered in the upper half of the image.

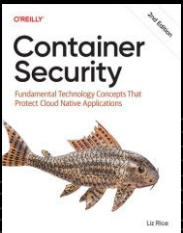
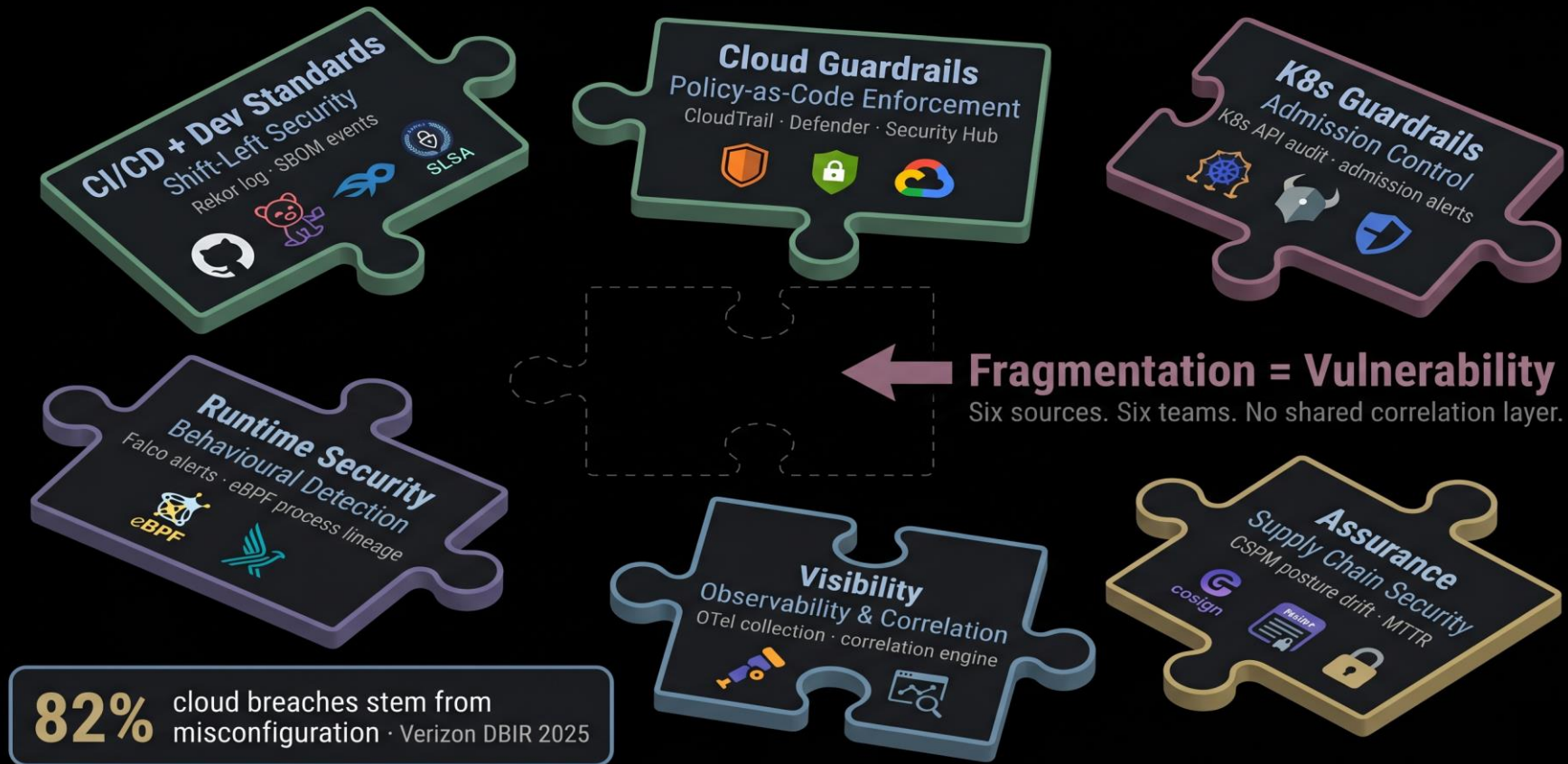
Cloud & Containers: The Security Puzzle That Locks Tight

Ashley Barker

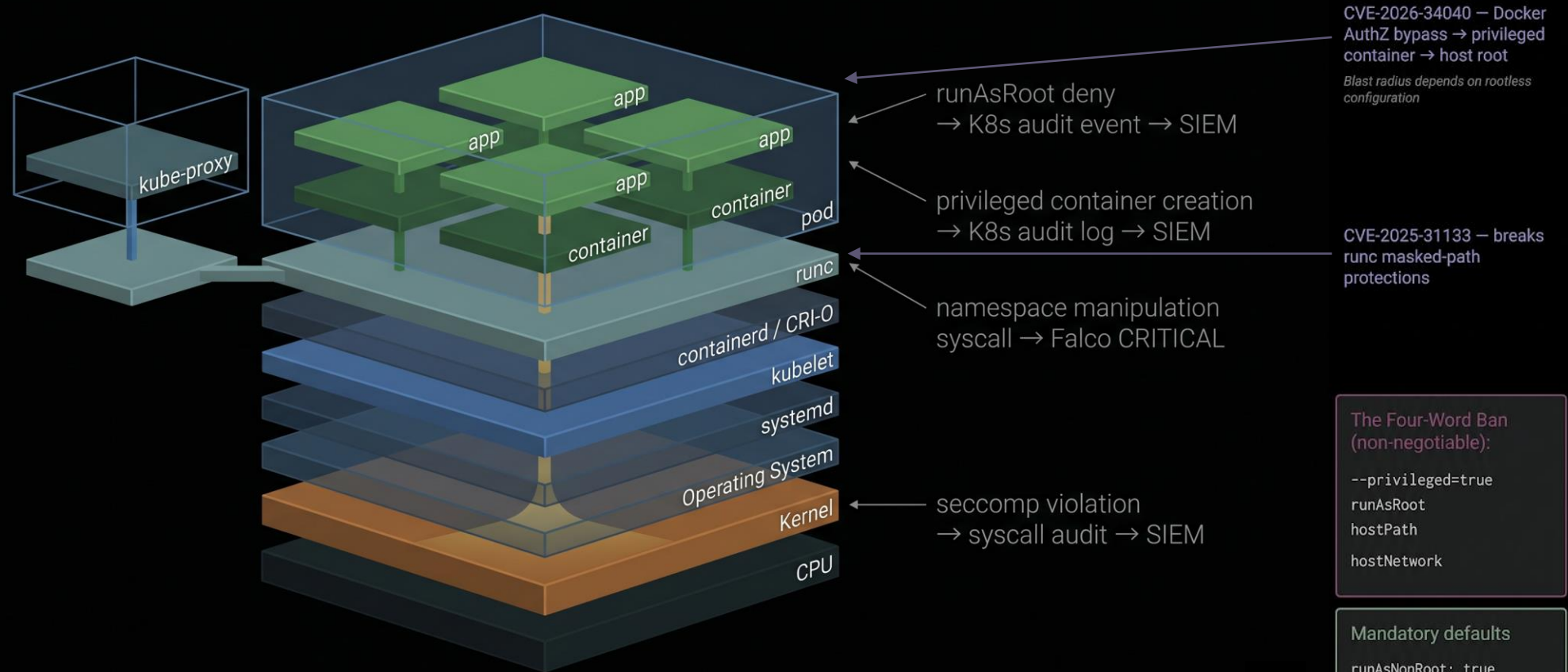
BSides Exeter 2026

Views expressed are my own and do not necessarily reflect those of my employer.

The Scattered Puzzle

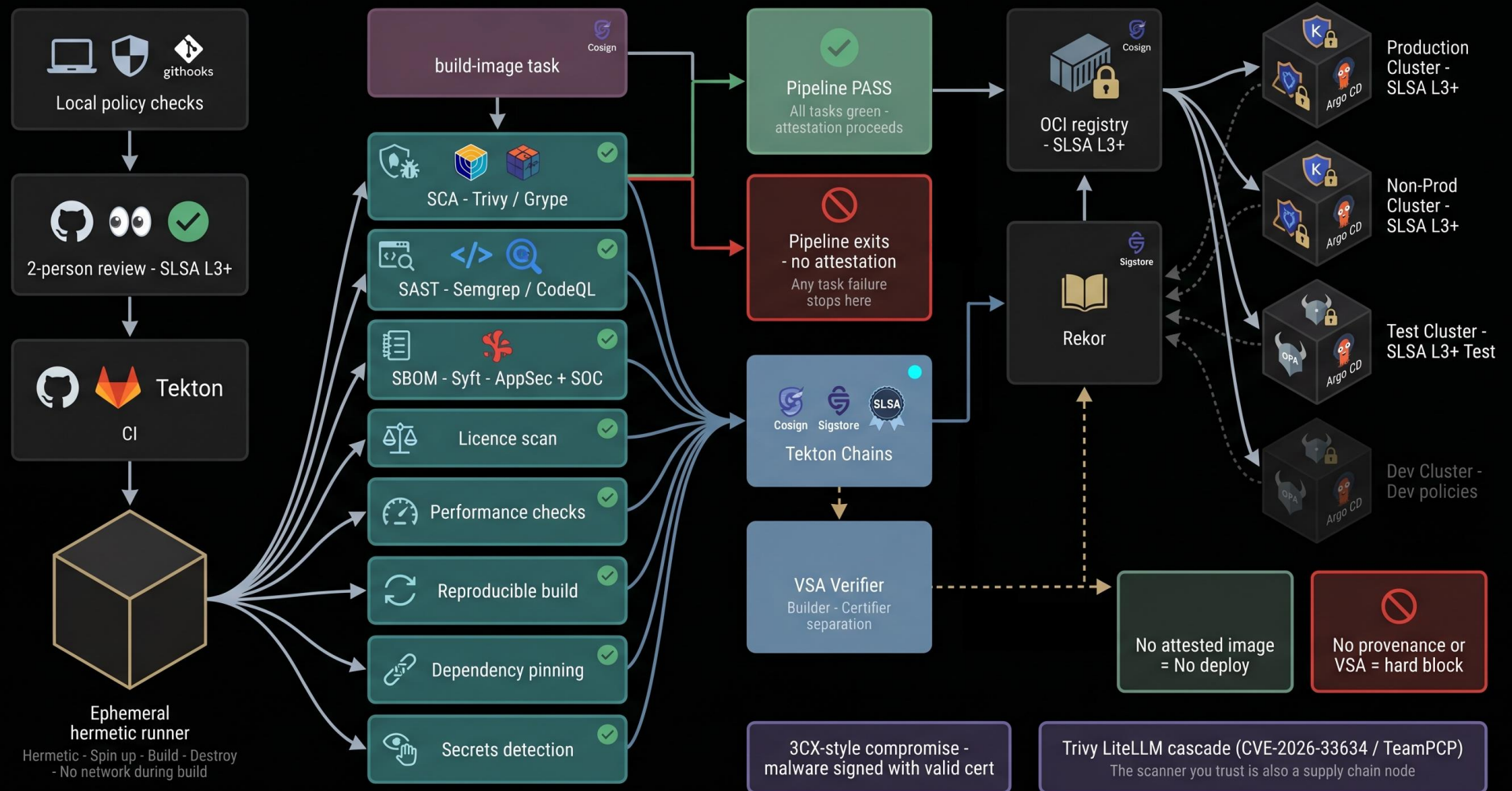


Foundations: The Shared Kernel Illusion



Containers are just processes sharing one kernel — the isolation is a mirage.

CI/CD: The Pipeline You Should Have



Who Sees What and the Missing Venn

Five signal sources. Three teams. One gap nobody owns.

Security engineering

- Policy-as-code enforcement
- VSA gate controls
- Admission controller logs
- Kyverno / OPA deny events

✓ Connected

AppSec

- SBOM generation and signing
- Shift-left CVE triage
- Licence review
- Dependency-Track findings

✓ Connected

SOC

- Deployment provenance — was this legitimate?
- Attested version at incident time
- Blast radius scope at incident time
- Failed VSA events and unusual build timing

- × IR team — manual at incident time
- × Threat hunters — rarely connected

× Not built

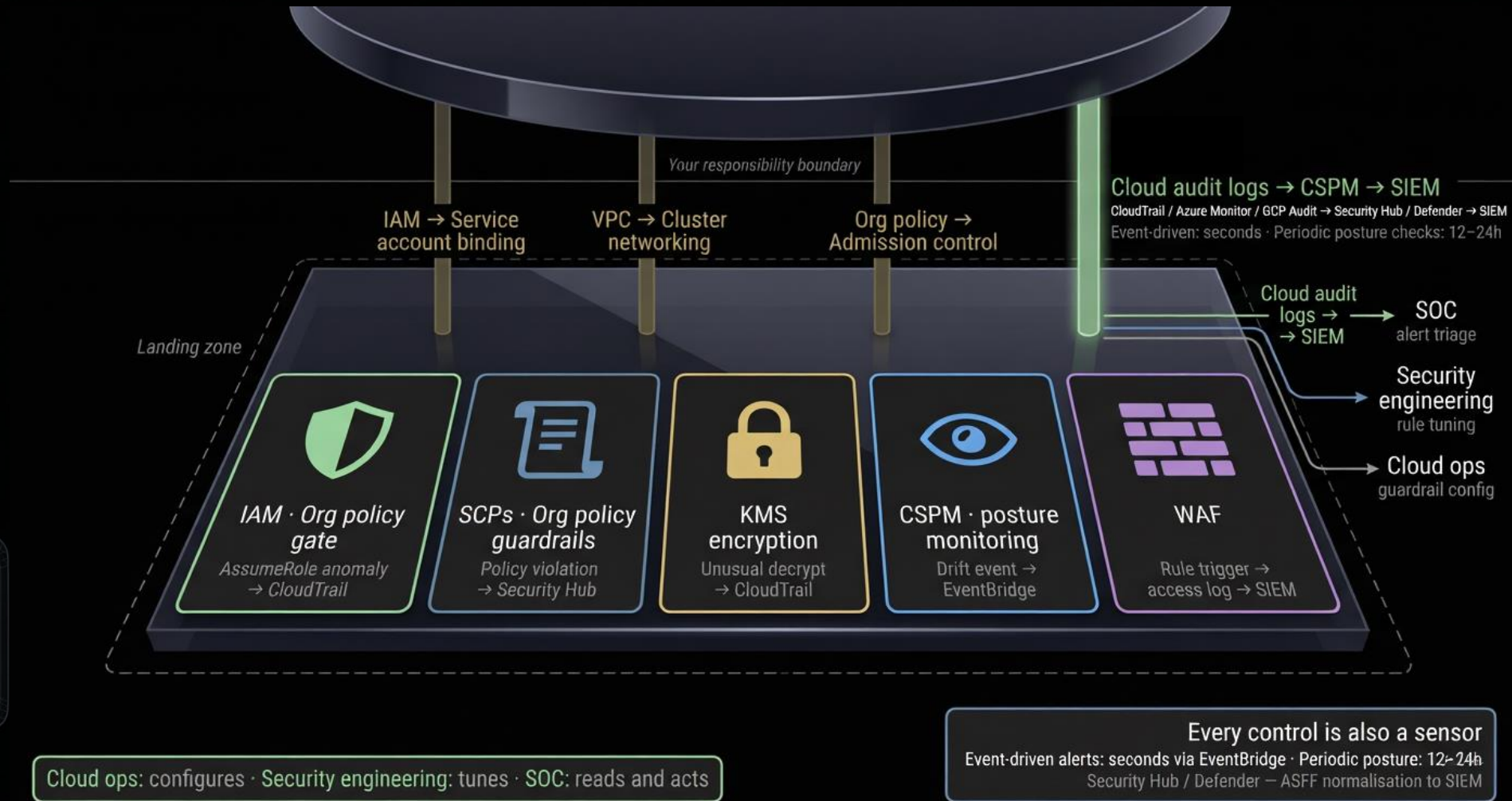
Five questions L1 needs to answer in 15 minutes

1. Scheduled deployment?
→ ITSM change ticket
2. Approved version?
→ Rekor: valid VSA?
3. Seen before?
→ Rekor provenance
4. Business impact?
→ CMDB / BIA classification
5. New push or scheduled release?
→ change window

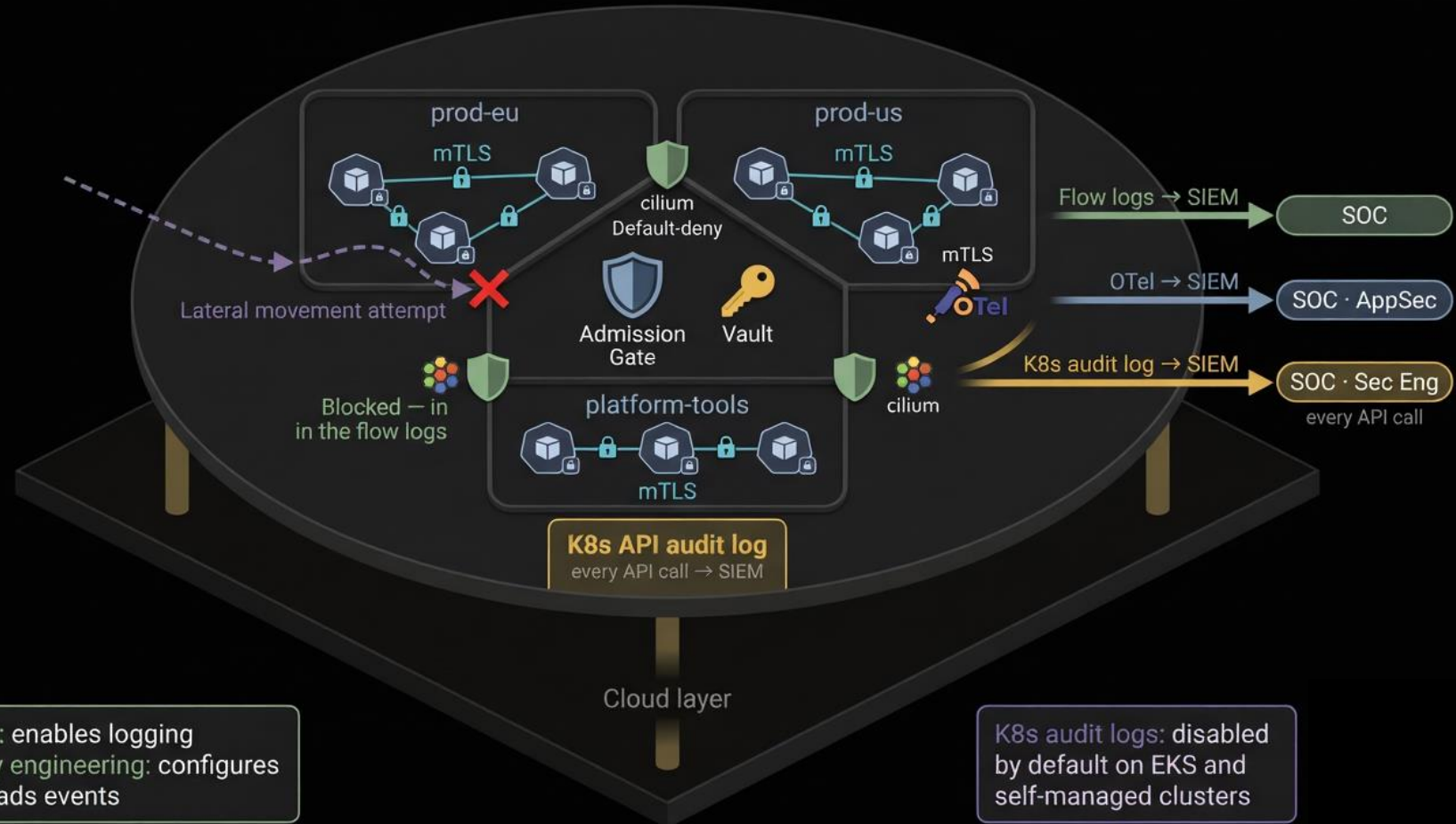
Rekor query: ~30 sec
ITSM lookup: ~30 sec

AppSec sees the SBOM finding. SOC sees the Falco alert.
Neither knows the other fired.

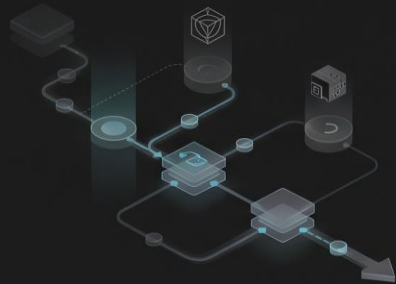
Cloud Guardrails as Sensors



K8s Guardrails as Sensors

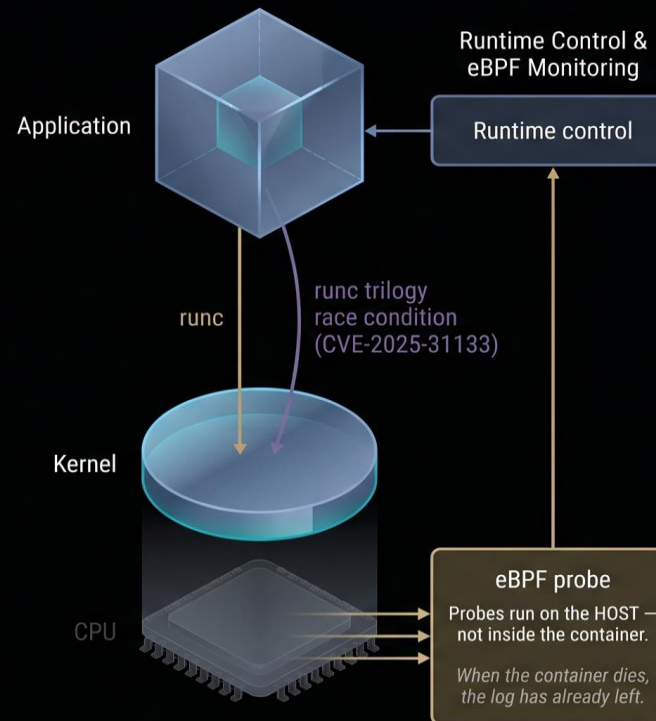


Runtime: eBPF Signal Generation



Shift-Left is blind
to runtime threats

Zero-days · Living-off-the-land
Ephemeral forensics · Drift



Behavioral baseline enforced
eBPF hooks on clone/fork/execveat

Nginx spawned /bin/sh — impossible behaviour

```
deploy-sa [serviceaccount]
→ pod: nginx-frontend-7d9f
→ nginx (pid 1) [expected]
→ /bin/sh (pid 2847) [IMPOSSIBLE]
→ curl ext-domain.com (pid 2848)
```

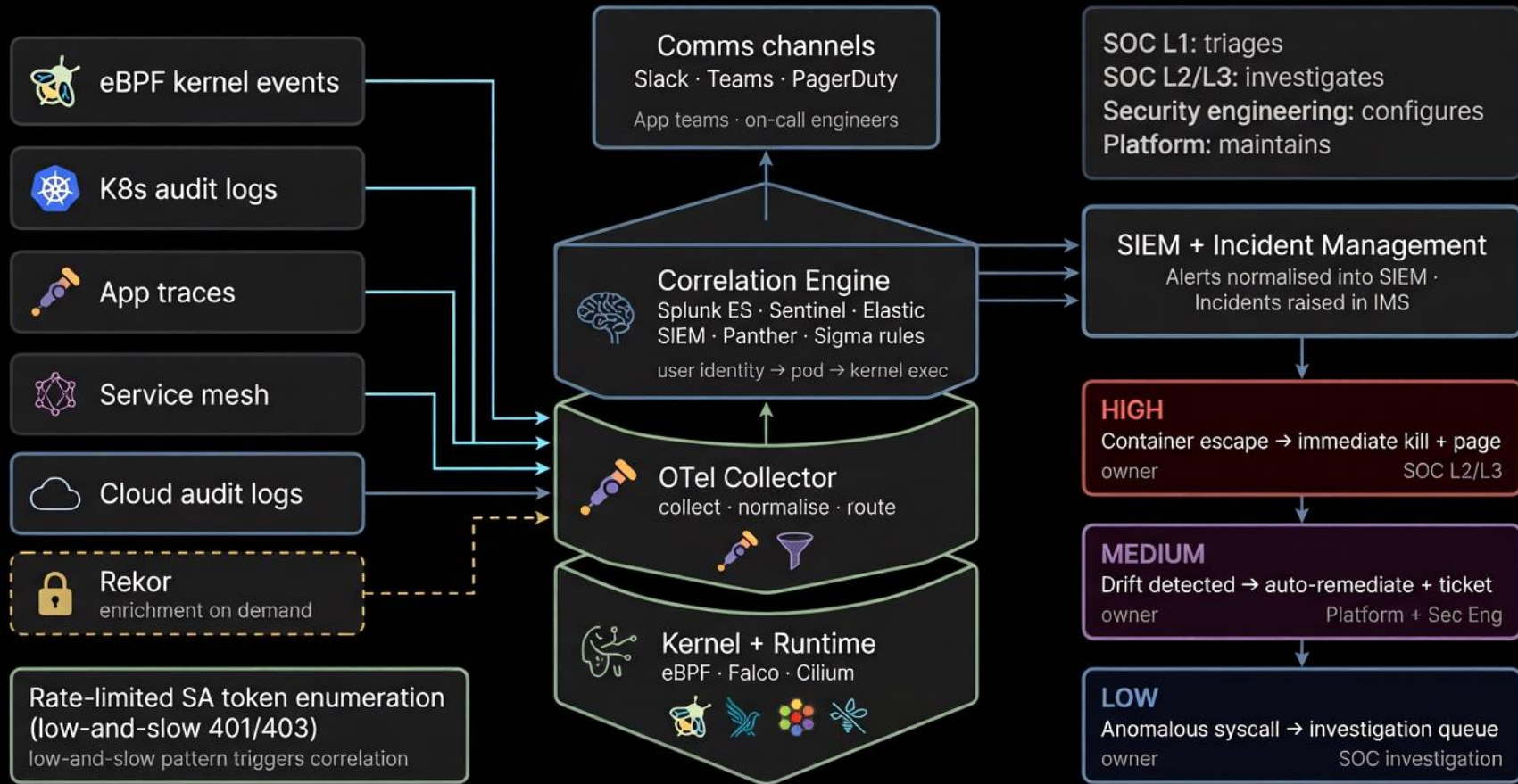
Reconstructed in SIEM from sequential Falco events

Role	Job
Security engineer	Writes Falco rules · Sets baselines · Owns Talon response config
SOC L2/L3	Reads lineage in SIEM · Correlates K8s audit · Triggers containment

Running fs/proc vs image manifest



The Unified Defence Graph



SOC Triage, Investigation and Response Loop

L1: First responder

15 min SLA

- Alert received
- ITSM lookup
- Data enrichment
- Rekor query on image digest
- Baseline check

Close + tuning note



Escalate L2 NOW

L2: Investigation

30 min SLA

- Process lineage
- Correlate - K8s audit logs
- Correlate - cloud audit logs
- Correlate - OTel traces

Kill: stops attack,
loses overlay



Preserve: keeps evidence,
attack continues

L3: Security engineering

- Revoke IAM
- Rotate credentials
- Which pipeline run? Other deployments?
- Which rule should have fired earlier?



Container

L2

- deny-all NetworkPolicy
- kubectl cordon
- automated pod kill



K8s cluster

L2/L3

- Revoke SA token
- Audit ClusterRoleBindings
- Scale to 0



Cloud

L3 + Sec Eng

- Revoke IAM role
- Rotate credentials
- VPC isolation



Pipeline

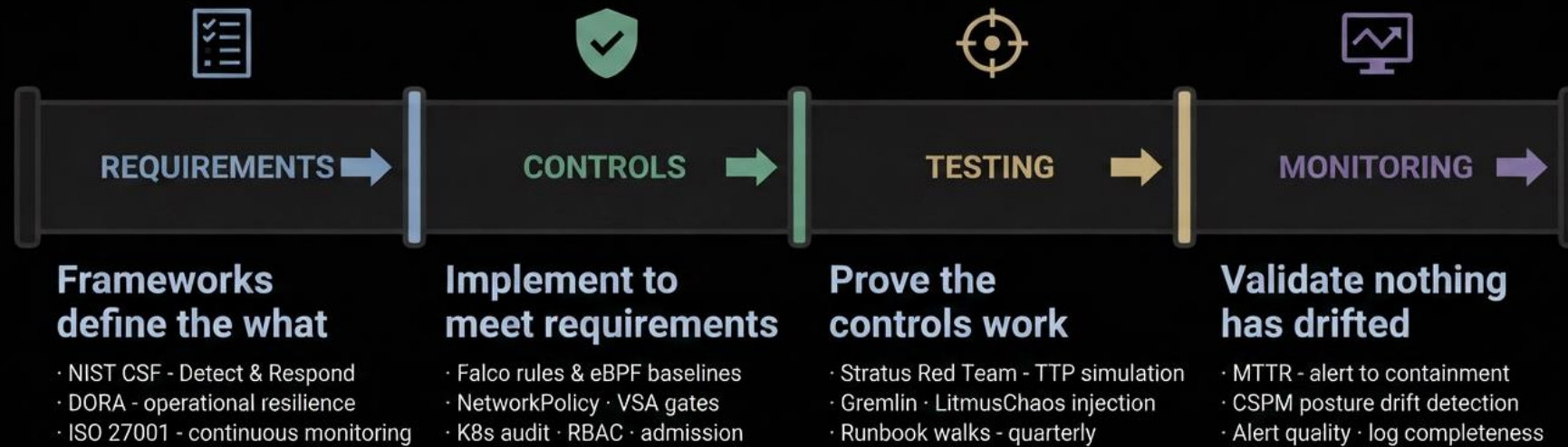
Sec Eng + AppSec

- Block image digest in admission
- Trigger clean rebuild

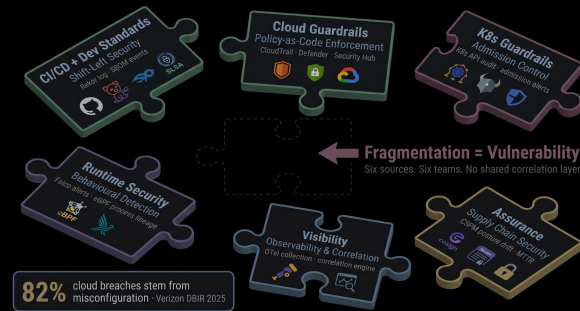
The logs left before the container did.

Logs must be extracted and shipped externally - L2 has the full lineage in the SIEM right now.

Assurance



The Four Actions for Monday



MANDATE TRUST

Enforce SLSA L3+ + VSA + automated revocation

"No attested image = No deploy"

431% YoY supply chain surge



ENFORCE CONTAINMENT

Default-deny NetworkPolicy + ban --privileged + CAP_DROP ALL

"Make the secure path the only path"

82% breaches from misconfiguration



DEPLOY VISIBILITY

eBPF runtime detection · External log shipping · K8s audit to SIEM

"Catch what scanners miss"

61% runtime exploits



DETECT AND RESPOND

Tuned Falco rules · Tested IR runbooks · Measured MTTR · People who own each layer

"The graph is assembled. Now use it."

CLOUD & CONTAINERS: THE SECURITY PUZZLE THAT LOCKS TIGHT



Six signal sources. One graph. Three tiers of human response.

Detection requires depth – not just deployment

Development → Build → Attestation → Admission → Runtime → Observability → SOC → Assurance

SIX SIGNAL SOURCES

1. Cloud Audit Logs → Security Hub / Defender → SIEM
2. K8s API Audit Logs → Fluent Bit DaemonSet → SIEM
3. Falco / Tetragon Alerts → Falco Sidekick → SIEM
4. Service Mesh Telemetry → OTel Collector → SIEM
5. Rekor → Query API (on-demand L1 enrichment)
6. Application Logs → OTel Collector → SIEM

All sources →

UNIFIED DEFENCE GRAPH

Every node a control. Every feed an edge.
Value is in the connections.

SOC TRIAGE LOOP

L1 – First Responder (15-min SLA)

- Alert pre-enriched: pod name · image digest · namespace · BIA classification
- ITSM lookup: change window open? (30 sec)
- Rekor query on image digest (30 sec)
- Decision: false positive | uncertain | confirmed → escalate L2

L2 – Investigation (30-min SLA)

- Process lineage in SIEM (Falco events, reconstructed)
- Correlate K8s audit events – same pod, same time window
- Kill-or-preserve decision
- Containment: deny-all NetworkPolicy via Falco Talon or kubectl

L3 / Security Engineering – Response

eBPF Monitoring + Active Response
Two-copy Logging: Hot + WORM Archive
L1 SLA: 15 min · P1 MTTF: 5 min
MTTR < 10 min for P1 container threat
Chaos Engineering: runbooks rehearsed

THE FOUR ACTIONS

MANDATE TRUST

Enforce SLSA L3+ + VSA + automated revocation
"No attested image = No deploy"

- CVE-2026-33634: malicious Trivy scanner · zero SIEM signal from pipeline
- 431% YoY supply chain surge
- Rotor: query image digest in 30 sec – valid VSA? Which runner? When built?

DEPLOY VISIBILITY

eBPF runtime detection cluster-wide with impossible-behaviour baselines
"Catch what scanners miss – at the kernel"

- Falco: proc.name · proc.pname · full process lineage reconstructed in SIEM
- The container is gone. The eBPF log is not.
- 61% of runtime exploits missed at build time

ENFORCE CONTAINMENT

Ban root & privileged + Default-Deny NetworkPolicies + CAP_DROP
"Make the secure path the only path"

- THE FOUR WORD BAN: --privileged | runAsRoot | hostPath | hostNetwork
- Also ban hostPID / hostIPC · No exec/attach
- 82% of breaches = misconfiguration
- K8s audit logs: disabled by default on EKS/AKS

DETECT AND RESPOND

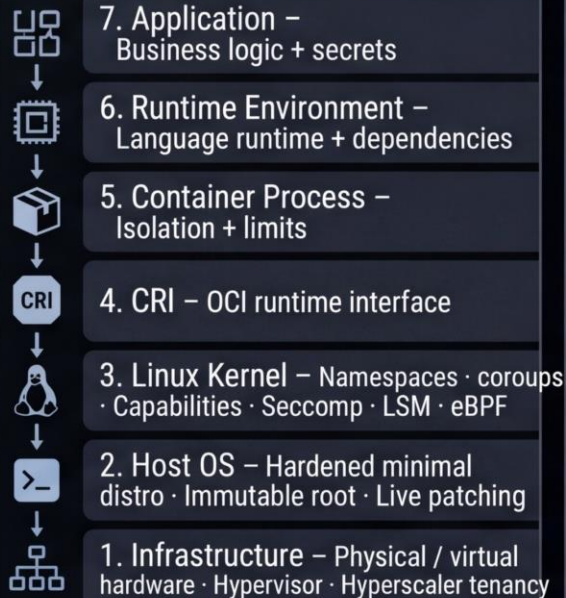
Falco rules tuned · Response runbooks tested · MTTR measured
"The graph is assembled. Now use it:"

- L1 SLA: 15 min · P1 MTTF: 5 min to first action (NetworkPolicy)
- Kill-or-preserve decision · Two-copy logging: hot tier + WORM archive
- MTTR target: under 10 min for P1 container threat

TARGET STATE

100% Attestation Coverage
0% Privileged / Root Pods
SLSA L3+ Provenance on every image
K8s Audit Logs shipped to SIEM
eBPF Monitoring + Active Response

7 LAYER MODEL



WHO OWNS WHAT

AppSec → Pipeline signals · SLSA · VSA · SBOM · SCA results
Sec Eng → eBPF rules · Falco tuning · Admission webhooks · Seccomp profiles
SOC L1 → Alert triage · ITSM enrichment · Rekor query · BIA classification
SOC L2 → Process lineage · Kill-or-preserve · Falco Talon containment
SOC L3 / IR → Cloud isolation · Credential rotation · Pipeline pivot · Tuning loop
Threat Hunting → Baseline deviation · Enumeration patterns · Lateral movement

Container Security · Cloud Security · Detection & Response · Zero Trust · Unified Defence Graph · Continuous Verification © Ashley Barker 2026